Stage 2

Overview :-

- 1. Preparation: Define Objectives: Determine the scope and objectives of the scan. What systems or networks do you want to assess, and what specific vulnerabilities are you looking for? System Access: Ensure that you have the necessary permissions and access rights to scan the target systems or networks.
- 2. Configuration: Set Up Scan Policy: Create a scan policy that defines the parameters of the scan, such as the types of vulnerabilities to check for, scanning frequency, and specific configurations. Define Target Assets: Specify the IP addresses, hostnames, or network ranges of the systems you want to scan.
- 3. Scanning: Initiate Scan: Start the Nessus scan using the configured policy and target assets. Nessus will systematically scan the target systems for vulnerabilities based on its plugins and policies.
- 4. Vulnerability Identification: Nessus performs a comprehensive assessment, checking for vulnerabilities, misconfigurations, open ports, and other security issues. As the scan progresses, it categorizes vulnerabilities by severity, making it easier to prioritize remediation efforts.
- 5. Reporting: Nessus generates detailed reports that list the vulnerabilities discovered during the scan. Reports typically include information about the severity of each vulnerability, recommended actions for remediation, and supporting evidence. These reports can be customized and exported in various formats, such as PDF, HTML, or CSV.
- 6. Remediation: Review Findings: IT and security teams review the Nessus scan reports to prioritize and address the identified vulnerabilities.
- Remediation Steps: Take corrective actions to fix or mitigate the vulnerabilities. This may involve applying patches, changing configurations, or implementing security measures.

Target website — testfire.net
Target ip address:- 54.83.41.36

List of vulnerability —

s.no	Vulnerability name	Severity	plugins
1	Cross-site scripting (stored)	Low	Web application Scanner
2	Broken Access Control	Medium	SSH weakHMAC Algorithms Supported
3	SQL Injection	Medium	N/A
4	Broken Authentication	Low	HSTS Missing from Server
5	webserver allows password autocompletion	Low	SSL/TLS Diffie-Hellman Modulus<=1024 bits(Logjam)

REPORT:-

Vulnerability Name:- Cross site scripting (stored)

severity : - Low

Plugin:- web application scanner

Port :- N/A

Description:- It occurs when a malicious script is injected directly into a vulnerable web application. Reflected XSS involves the reflection of a malicious script of a web application, onto a user's browser.

solution:- When interacting with databases, use parameterized statements or prepared statements to avoid SQL injection, which can be a vector for XSS.

• Sanitize and validate all user inputs and ensure that any data displayed on the web page properly encoded. Use output encoding libraries or functions to prevent script injection.

Business Impact::- The application stores dangerous data in a database, message forum, visitor log, or other trusted data store. Later, the dangerous data is subsequently read back into the application and included in dynamic content. From an attacker's perspective, the optimal place to inject malicious content is in an area that is displayed to either many users or particularly interesting users. Interesting users typically have elevated privileges in the application or interact with sensitive data that is valuable to the attacker. If one of these users executes malicious content, the attacker may be able to perform privileged operations on behalf of the user or gain access to sensitive data belonging to the user.